CISSP Domain 1〜6｜分類別・最重要チートシート

> **学習目的**：暗記だけでなく、設問を見て「どの原則・法制度・モデル・技術・判断が必要か」を瞬時に選ぶ。
> **基礎資料**：末尾に示す GitHub `yutayadu/learning` の Domain 1〜6（2026-10-26確認）。
> **凡例**：**★★★＝最優先、★★＝高優先、★＝余裕があれば。**優先度は試験の公式出題頻度ではなく、本ノートの復習用推奨順。
> **範囲**：Domain 1〜6限定。Domain 7・8は未収録。GitHubノートにあった説明を中心に再構成し、必要な理解上の注意や設問例は「試験向け補足」として記載。

---

0. 最初に叩き込む：CISSPの判断原則 ★★★

状況	まず考えること	陥りやすい間違い
何を導入すべきか	**事業目標→資産→リスク評価→管理策選択**	ツール購入から始める
許容できないリスクがある	**リスクオーナー／適切な経営権限者へ報告して対応判断**	技術担当が独断でリスク受容
認証に成功した利用者がいる	**認可はリソース・操作ごとに別途判定**	ログイン成功＝無制限アクセス
外部事業者に委託する	**リスクの説明責任は委託元に残る**	クラウドに移したら責任ゼロ
管理策が導入済み	**証拠とテストで運用有効性を評価**	設定したから安全だと決めつける
本番環境に侵入テストしたい	**書面による許可・スコープ・ROEを先に決定**	良かれと思って無断テスト
インシデントや監査指摘が出た	**影響把握→対応→文書化→改善・再評価**	修正するだけで原因や証跡を残さない
緊急時に業務を止められない	**人命・安全→事業継続→システム復旧**	システム稼働率のみで判断
対策に費用がかかる	**リスク低減効果と費用、残余リスクのバランス**	何でも最高水準の対策にする
CISSPの「BEST/FIRST/MOST」が出た	**条件・組織の責任・意思決定の順序**を読む	単語を見た瞬間に技術を選ぶ

覚え方：「経営が目的を定め、データオーナーが保護要件・権限を決め、技術担当が実装し、監査が検証する」。

---

1. 法律・制度・規制・契約 ★★★（主にD1・D2・D6）

1.1 各法律は「誰の何を守るか」で覚える

制度・法律	国・対象	核心	具体例・キーワード
GDPR ★★★	EU/EEA関連の個人データ処理（域外適用もあり得る）	個人の権利、処理の正当性、管理者の説明責任、越境移転	削除権、データポータビリティ、管理者/処理者、DPIA
HIPAA ★★★	米国・対象となる医療機関、保険者、関連受託者等	**PHI**（保護対象保健情報）	病院の患者情報、Business Associate Agreement（BAA）
GLBA ★★★	米国・金融機関の顧客情報	顧客の非公開個人情報の保護	金融機関の顧客データ、セーフガード
SOX ★★★	米国・主に上場企業の財務報告	財務報告の信頼性と内部統制	会計不正、変更管理・監査証跡、SOC 1との関連
FERPA ★★	米国・対象教育機関	学生の教育記録のプライバシー	大学の成績・教育記録
COPPA ★★	米国・13歳未満の子どもを対象とするオンラインサービス等	子どもの個人情報収集への保護者同意等	子ども向けWebサービス
FISMA ★★	米国・連邦政府の情報セキュリティ	政府情報・システムに対するリスク管理	NIST、RMF、継続的モニタリング
CFAA ★★	米国・コンピュータ不正アクセスなど	不正なコンピュータ活動の規制	無許可侵入、権限逸脱
DMCA ★★	米国・デジタル著作物	著作権と技術的保護手段	DRM回避、研究・法的例外の検討
ECPA ★	米国・電子通信のプライバシー	電子通信の傍受・開示等	メールや通信への不適切なアクセス
CALEA ★	米国・対象通信事業者	適法な傍受に対応する能力	法執行機関の正規の要請
PCI DSS ★★★	**法律ではなく**決済カード業界の基準	カード会員データの保護	カード番号を扱うECサイト
ePrivacy Directive ★★	EU・電子通信	Cookie、通信秘密、電子マーケティング等	Web追跡・通信プライバシー
ワッセナー・アレンジメント ★	国際輸出管理	兵器・軍民両用品（暗号関連技術を含む場合）の輸出管理	高度な技術の国外提供

誤記に注意：正式名称は **HIPAA**（HIPPAではない）。**GDPRは2016年制定・2018年適用開始。PCI DSSは業界基準であり、SOX・HIPAAと同じ「法律」ではない。**

1.2 GDPRとプライバシー：暗記対象

GDPR第5条：6原則＋説明責任

原則	覚える言葉	典型的な違反例
適法性・公正性・透明性	正当な根拠、分かる説明	根拠なく顧客データ取得
目的の限定	収集目的以外に勝手に使わない	決済情報を無関係な広告へ転用
データの最小化	必要な情報だけ	配送に不要な病歴まで要求
正確性	正しく更新	誤った住所を放置
保存期間の制限	必要以上に持たない	不要になった個人情報を永久保存
完全性・機密性	適切な安全管理	暗号化もアクセス制限もなし
説明責任（Accountability）	遵守を実証する	方針もログも証拠もない

GDPRの登場人物：Data Subject＝本人、Controller＝目的と手段の決定者、Processor＝委託等で処理する者、DPO＝個人データ保護の監督・助言を担う役割。**DPOとControllerは同じものではない。**

主な権利：アクセス、訂正、消去（忘れられる権利）、データポータビリティなど。**削除権は無条件ではなく、法定保存など例外がある。**

越境移転：十分性認定、標準契約条項等の適法な仕組みを検討。過去の **EU-US Privacy Shield は2020年に無効化**されており、現在の適法性をその制度に依拠して説明してはいけない（教材の歴史的記載との区別）。

OECDプライバシー8原則：収集制限・データ品質・目的明確化・利用制限・安全保護・公開・個人参加・責任。**GDPRの条文上の原則と完全に同じリストではない。**

1.3 知的財産（IP）の4分類と契約

保護制度	守るもの	例／識別ポイント
著作権	具体的な創作物の表現	ソースコード・設計書。「アイデアそのもの」は一般に別問題
特許	要件を満たす発明	技術的発明の独占的権利（通常、出願日から20年を基本に法域・例外あり）
商標	出所を識別する名称・ロゴ	製品名やブランドマーク、更新可能
営業秘密	秘密として管理し価値を持つ情報	顧客名簿、未公開アルゴリズム、内部ノウハウ

NDA：秘密保持契約。**EULA**：ソフトウェアのエンドユーザー使用許諾。**AUP**：許容されるシステム利用規程。**SLA**：サービス水準の合意。**BAA**：HIPAA対象データを扱う関連事業者との契約。

---

2. 規格・フレームワーク・制度の地図 ★★★（D1・D3・D6）

2.1 「どの文書が何をするか」最重要表

名称	何を定義するか	試験での識別文
ISO/IEC 27000	ISMS関連の用語・概念	**用語集**
ISO/IEC 27001	ISMSの**要求事項**	**ISMS認証を取得したい**
ISO/IEC 27002	情報セキュリティの**管理策ガイダンス**	**具体的な管理策の説明**
ISO/IEC 27005	情報セキュリティリスク管理	**リスクの特定・評価・対応**
ISO 31000	全社的・分野横断のリスク管理	**情報セキュリティ以外も含むリスク**
ISO 22301	**BCMSの要求事項**	**事業継続マネジメント**
ISO 22300	セキュリティ・レジリエンス／BC関連の用語	**BCの辞書**
NIST CSF 2.0	サイバーリスク管理の成果の整理	**Govern, Identify, Protect, Detect, Respond, Recover**
NIST SP 800-37	**RMF**のプロセス	**Prepare→Categorize→Select→Implement→Assess→Authorize→Monitor**
NIST SP 800-53	セキュリティ・プライバシー管理策の**カタログ**	**どんな統制を選ぶか**
NIST SP 800-53A	管理策の**評価・テスト方法**	**Examine・Interview・Test**
NIST SP 800-30	リスクアセスメントの方法	**脅威・脆弱性・影響分析**

名称	何を定義するか	試験での識別文
NIST SP 800-39	組織全体のリスク管理	**組織・業務・システムの3階層**
NIST SP 800-34	情報システムのコンティンジェンシプラン	**IT継続・復旧**
NIST SP 800-63	デジタルIDの保証	**IAL・AAL・FAL**
NIST SP 800-92	セキュリティログ管理	**収集・保護・分析・運用**
NIST SP 800-171	非連邦システム等でのCUI保護要件	**Controlled Unclassified Information**
NIST SP 800-207	ゼロトラストアーキテクチャ	**暗黙の信頼を置かない**
NIST SP 800-88	媒体のサニタイズ	**Clear・Purge・Destroy**
FIPS 199	CIA別のセキュリティ影響度分類	**Low・Moderate・High**
FIPS 200	連邦情報システムの最低限のセキュリティ要求事項	**要求事項の領域**
COBIT	ITガバナンスとマネジメント	**経営目標とのIT統制の整合**
SABSA	ビジネス主導のセキュリティアーキテクチャ	**事業要件から設計**
COSO	内部統制・全社リスク管理	**取締役会・財務統制・17原則**

名称	何を定義するか	試験での識別文
FedRAMP	米国連邦政府のクラウドセキュリティ評価・認可の枠組み	**政府調達・クラウドの保証**
CSA STAR	クラウド事業者のセキュリティ保証・透明性	**クラウドサービスの保証情報**

版に注意：ISO/IEC 27001:2013 と 2022 ではAnnex Aの管理策番号・構成が変わる。**NIST RMFは7段階、CSF 2.0は6機能**。この2つの順番や目的を混ぜない。

2.2 SOC／監査保証の見分け方 ★★★

区分	主な目的	主な読者・例
SOC 1	**財務報告に係る内部統制**	会計監査人、委託先の給与計算が財務報告に影響する企業
SOC 2	**Trust Services Criteria（TSC）**に基づく統制	SaaSのセキュリティ保証を求める取引先
SOC 3	SOC 2と関連する**一般利用者向けの要約的報告**	顧客向けに公開する保証情報
SOC for Cybersecurity	組織全体のサイバーリスク管理プログラムに焦点	特定サービスだけに限らない全社的な説明
Type 1	**特定時点**で統制の記述・設計を評価	「ある日の状態は？」
Type 2	**一定期間**の**運用有効性**を追加評価	「半年を通じて動いていた？」

Type 1/2は主にSOC 1・2の区分。SOC 3を「Type 3」と誤解しない。**SOC 2のTSCは Security・Availability・Processing Integrity・Confidentiality・Privacy**。TSCは必ず5つ全部を評価するという意味ではなく、契約・適用範囲に応じる（Securityは共通基準）。

SAS 70 → SSAE 16 → SSAE 18：米国のサービス組織保証に関する歴史的な移行・更新。**ISAE 3402** は国際的なサービス組織の統制に関する保証基準。**SOC 1・2・3と監査基準（SSAE/ISAE）を同列の製品名として扱わない**。

2.3 産業・分野特化の基準

規格等	主な対象
PCI DSS	決済カード情報
IEC 62443	産業制御システム（ICS/OT）

規格等	主な対象
NERC CIP	北米の電力系重要インフラ
Cyber Essentials	英国の基礎的サイバー対策スキーム
UL 2900	ネットワーク接続製品等のサイバーセキュリティ評価
SWIFT CSCF	SWIFT利用組織のセキュリティ統制
ISAE 3000	財務諸表監査以外の保証業務の一般的枠組み
ISO/IEC 27017・27018	クラウド管理策・パブリッククラウド上のPII保護

2.4 ポリシー体系とセキュリティコントロールの分類 ★★★

文書	拘束力・役割	例
Policy（ポリシー）	経営方針・組織の原則	個人データを適切に保護する
Standard（スタンダード）	守るべき具体的な共通要件	保存データを承認済みの方式で暗号化する
Procedure（手順）	作業を再現可能にする手順	管理画面で暗号化設定を変更する操作順
Guideline（ガイドライン）	推奨事項・判断の手引き	要件を満たす実装の推奨例
Baseline（ベースライン）	最低限満たす標準的設定・管理策のセット	OSの安全な初期構成

管理策のカテゴリーは「何で実現するか」、**機能タイプ**は「何をさせるか」という別の分類。

カテゴリー	例
管理的／組織的	規程、教育、承認、職務分離
技術的／論理的	MFA、FW、暗号化、DLP
物理的	鍵、ゲート、警備員、監視カメラ

機能タイプ（7種類）	目的	一言で覚える例
Directive	**指示**する	AUP、標識
Deterrent	**抑止**する	「監視中」の警告
Preventive	**防止**する	FW、MFA、施錠
Compensating	他の対策で**補償**する	レガシー機器を隔離ネットワークへ
Detective	**検知**する	IDS、SIEM
Corrective	**是正**する	障害原因の修正・パッチ
Recovery	**復旧**する	バックアップからリストア

同じ製品が複数タイプの役割を担う場合がある（監視カメラは抑止と検知等）。機能で分類する。

---

3. セキュリティモデル・原則・脅威分析 ★★★（D1・D3・D5）

3.1 必ず比較して覚える「6つのモデル」

モデル	守るもの	暗記するルール	銀行・企業の具体例
Bell-LaPadula（BLP）★★★	**機密性**	**No Read Up / No Write Down**	Secret権限の人はTop Secretを読めず、Top Secretの情報を下位へ書き出せない
Biba ★★★	**完全性**	**No Read Down / No Write Up**	低信頼の入力を高信頼の会計台帳へ直接書き込ませない
Brewer–Nash / Chinese Wall ★★★	**利益相反の防止**	**過去のアクセス履歴で許可が変化**	A銀行を担当したコンサルは競合B銀行の秘密情報にアクセスしない
Clark–Wilson ★★★	**商用トランザクションの完全性**	**職務分離・適正処理（TP）・検証（IVP）**	送金申請者と承認者を分け、正規プログラムだけで残高更新
Graham–Denning ★★	**主体・客体・権限の安全な管理**	**生成・削除・権限付与/変更等の8つの基本操作**	アカウント作成・アクセス権付与の手続き
Harrison–Ruzzo–Ullman（HRU）★★	**アクセス制御モデルの安全性分析**	**Safety Problem：権限が漏れ得るか**	一連の権限委譲で本来無権限の人が閲覧できないか分析

記憶フック：BLP＝秘密は下に流さない。Biba＝汚染を上に上げない。Chinese Wall＝競合を両方見ない。Clark–Wilson＝正規手順＋二人チェック。

モデルを1分で具体化

- **BLP（機密性）**：機密レベル「一般＜社外秘＜極秘」。極秘担当者が社外秘DBに書けたら機密が下に漏れ得るので禁止。
- **Biba（完全性）**：高信頼な財務台帳を、未検証の外部データで書き換えてはならない。上下の見方がBLPと逆。
- **Brewer–Nash**：同じ業界の競合AとBの機密データに同一担当者を触れさせない。業界が違うC社なら許可され得る。
- **Clark–Wilson**：`UDI（未検証のデータ）→ 検証・認可済みTP → CDI（統制対象データ）`。**IVP**はCDIの整合性検証。

3.2 基本原則（似た言葉の取り違え防止）

原則	意味	最も分かりやすい例

原則	意味	最も分かりやすい例
Least Privilege	業務に必要な最小権限	閲覧担当にDB更新権限を与えない
Need to Know	その情報を知る業務上の必要性	同じ機密区分でも担当外文書は見せない
Separation of Duties	重要業務を一人で完結させない	送金の起票と承認を分離
Defense in Depth	独立性のある複数の防御層	FW＋MFA＋EDR＋ログ監視
Fail Secure	障害時にも安全な状態を維持	認可サービス停止時に管理画面を全面許可しない
Secure by Default	初期設定から安全	不要なポートやアカウントを最初から閉じる
Complete Mediation	アクセス要求ごとに適切な認可判定	ログイン後のAPI呼び出しでも権限確認
Zero Trust	ネットワークの内外による暗黙の信頼を排除	社内LANでも端末状態・ID・リスクを検証
Reference Monitor	すべてのアクセスを仲介する参照機構	検証可能・改ざん耐性・迂回不能であることが重要
Ring Protection	特権の高低を階層化	OSカーネルと利用者アプリを分離
Noninterference	高機密処理が低機密の観測結果を不正に変えない	高機密処理から低位ユーザーへの情報漏れ防止

補足：Fail Secureと人命保護が衝突する物理扉では、避難規程や生命安全の要請を優先して設計する。**Fail Safe（安全側に倒す）**を「必ず解錠／必ず施錠」の一律ルールにしない。

3.3 STRIDE：脅威モデルの6文字 ★★★

文字	脅威	何を侵すか	例
S	Spoofing（なりすまし）	認証・真正性	他人の資格情報でログイン
T	Tampering（改ざん）	完全性	送金額を書き換える
R	Repudiation（否認）	説明責任・否認防止	「そんな送金はしていない」
I	Information Disclosure（情報漏えい）	機密性	顧客情報を外部取得
D	Denial of Service（サービス妨害）	可用性	APIをリクエストで過負荷にする
E	Elevation of Privilege（権限昇格）	認可	一般ユーザーが管理操作を行う

DREAD：Damage・Reproducibility・Exploitability・Affected users・Discoverability の評価観点（歴史的手法）。**PASTA**は攻撃・ビジネス影響を含む脅威分析の方法論。**STRIDE＝脅威の種類を列挙、DREAD＝優先付けの一方法。**

4. リスク分析・計算・BC/DR ★★★（D1・D3・D6）

4.1 4つのリスク対応

リスク対応	意味	例
低減（Mitigate）	発生確率または影響を下げる	EDR・バックアップ・MFAを導入
回避（Avoid）	リスクの原因となる活動をやめる	危険なサービスの提供を中止
移転／共有（Transfer/Share）	損失の一部を他者に負担してもらう	サイバー保険（説明責任は移転しない）
受容（Accept）	残余リスクを認識して受け入れる	権限者が文書化・承認し期限付きで例外運用

Risk Appetite＝組織が戦略的に取る意思のあるリスク水準。**Risk Tolerance**＝目的達成上許容する変動・範囲。**Residual Risk**＝管理策適用後にも残るリスク。責任者の承認なしに技術者が残余リスクを受容しない。

4.2 定量評価の3つの公式

記号	意味	公式
AV	Asset Value（資産価値）	評価額
EF	Exposure Factor（1回の事故で失う割合）	0〜1の割合
SLE	Single Loss Expectancy（1回の損失）	**AV × EF**
ARO	Annualized Rate of Occurrence（年発生率）	年間発生頻度
ALE	Annualized Loss Expectancy（年間期待損失）	**SLE × ARO**

例： 1,000万円のサーバー（AV）、事故で40%損失（EF=0.4）、2年に1回（ARO=0.5）→ **SLE=400万円、ALE=200万円/年**。対策導入費と予測損失低減を比較する。ただし数式だけで法令義務や人命リスクを無視しない。

定量評価は金額・確率で比較しやすいが、データ品質に依存。**定性評価**は高・中・低、専門家判断などで評価しやすいが、評価のばらつきに注意。**FAIR**は情報リスクを要因分解して分析するアプローチ。

4.3 BC/DRで絶対間違えない4指標

指標	答える質問	例
MTD / MAD	**最大でどれだけ業務停止に耐えられる？**	24時間を超えると事業が成立しない
RTO	**何時間以内にシステム・サービスを復旧させる？**	4時間以内に復旧
WRT	**システム復旧後、業務が正常化するまで？**	未処理取引の再入力に2時間
RPO	**何時間分のデータ損失を許容する？**	最大15分前まで復元

教材での関係：`RTO + WRT ≤ MTD/MAD` を目標に設計する（システムが復旧しても、業務再開には追加作業があり得る）。**RTO＝時間、RPO＝過去のデータ時点。**

代替サイトと演習（比較で出る）

選択肢	概要	トレードオフ
Hot Site	ほぼ即時利用できる設備・システム	高コスト・短い復旧時間
Warm Site	一部設備・構成が準備済み	中間
Cold Site	場所・基本インフラ中心、機器等は追加手配	低コスト・長い復旧時間
Checklist/机上チェック	文書・連絡先を確認	リスク最小・実効性の検証は限定的
Walkthrough	手順を順に読み合わせ	役割・手順の矛盾を発見
Tabletop	災害シナリオの意思決定を議論	指揮命令や連絡能力を確認
Simulation	インシデントを模擬して対応	実践性が高い
Parallel	本番を動かしたまま代替側で試験	本番リスクを抑えた動作確認
Full Cutover	本番業務を代替サイトへ実際に切り替える	最も現実的だが事業リスクも高い

BIA → 重要業務・依存関係・影響・許容停止の特定 → 継続戦略 → 計画 → 訓練 → 改善。BC＝事業全体を継続、DR＝主にITシステムを復旧。**バックアップ取得成功と実際に復元できることは別。**

5. 資産・データ分類・取り扱い ★★★（D2）

5.1 分類とカテゴリー化

概念	目的	例
Classification（分類）	保護水準・機微性を決める	Public / Internal / Confidential / Highly Restricted
Categorization（カテゴリー化）	情報の種類・損失影響や業務上の性質を捉える	PII、PHI、財務、生命安全、時間制約
FIPS 199	CIAへの影響を各々Low/Moderate/Highで決める	機密性High・完全性Moderate・可用性Low
High-water mark	情報システム全体の影響度に最も高い値を採用	一つがHighならシステム影響度はHigh

原則：**データオーナーが価値・分類・権限を決定し、カストディアンが運用・保護を実施。**分類はラベルを貼る行為だけでなく、保護・利用・保持・廃棄要件を変えるための前提。

5.2 データの関係者

ロール	担当	例
Data Subject	個人データで識別される本人	銀行顧客
Controller	個人データ処理の目的・手段を決める	銀行

ロール	担当	例
Processor	Controllerのためにデータを処理	受託クラウド事業者
DPO	個人情報保護に関する専門的助言・監督	組織のデータ保護責任者
Data Owner	データの分類・保護要件・権限決定に責任	顧客情報部門の責任者
Data Custodian	データの保管・バックアップ・技術統制の実装	DB管理者
Data Steward	データ品質・定義・利用ルール・業務上の管理	顧客マスタ管理者

注意：GDPRのController/Processorと組織内部のOwner/Custodianは異なる概念。必ずしも1対1対応しない。

5.3 データライフサイクル／3つの状態

ライフサイクル：作成 → 保存 → 利用 → 共有 → アーカイブ → 破棄。アクセス制御・暗号化・ログ・DLPを段階ごとに適用。

データの状態	対策	例
At Rest（保存）	ディスク暗号化、DB権限、鍵管理	ノートPC盗難でもデータを保護
In Transit / Motion（転送）	TLS・IPsec・暗号化メール	顧客情報をAPI転送
In Use（使用中）	メモリ保護、実行環境分離、アクセス制御	処理中の機密データ

DLPの流れ：**Discovery/Classification（発見・分類）→ Monitoring（監視）→ Enforcement（警告・遮断）**。メール送信（Motion）、ファイルサーバー（Rest）、コピー・貼り付け（Use）などを対象にする。

5.4 媒体廃棄とデータ残留

方法	意味	注意
Reformat	ファイルシステムの初期化	**機微データの消去保証にならない**
Clear	論理的な手段で通常の復元を防ぐ	媒体・技術の仕様に依存
Purge	より強い方法で回収を困難化	対応媒体での消磁、適切な暗号消去等
Destroy	物理的に利用不能にする	裁断・破砕等、再利用不可

SSDの注意：ウェアレベリングのため通常の上書きで全領域を消せるとは限らない。媒体に適した消去方法と、処分証跡が重要。**暗号消去の有効性は暗号化の事前実装と鍵の適切な破棄に依存。**

---

6. 暗号技術・PKI・認証付き保護 ★★★（D3）

6.1 守りたい性質から技術を選ぶ

技術	主に提供する性質	典型例	誤解しないこと

技術	主に提供する性質	典型例	誤解しないこと
対称暗号（AES等）	機密性	大量データの暗号化	鍵共有・鍵保護が必要
非対称暗号（RSA等）	機密性や署名の用途	公開鍵暗号、証明書	対称暗号より計算負荷が大きい傾向
DH/ECDHE	**鍵共有**	TLSセッション鍵合意	DH単体で相手の身元を認証しない
ハッシュ（SHA-256等）	改ざん検知に利用する要約値	ファイル整合性確認	鍵なしハッシュだけでは送信者を認証しない
MAC/HMAC	完全性・共有鍵ベースの真正性	APIメッセージ認証	共有鍵なので**単独で否認防止にならない**
デジタル署名	完全性・署名者の真正性・否認防止に寄与	電子契約、ソフトウェア署名	秘密鍵管理と本人への鍵の結び付けが必須
AEAD	暗号化＋完全性保護	AES-GCM、ChaCha20-Poly1305	単なる「暗号化」と区別
PKI/X.509	公開鍵の信頼と身元の結び付け	HTTPSサーバー証明書	証明書失効・用途・ホスト名も確認

公開鍵・秘密鍵の使い方

- **秘密のメッセージを送る**：**受信者の公開鍵**で暗号化 → **受信者の秘密鍵**で復号。
- **署名を付ける**：**送信者の秘密鍵**で署名 → **送信者の公開鍵**で検証。
- **TLS等のハイブリッド暗号**：公開鍵技術で認証・鍵合意し、実データは高速な対称暗号で保護。

6.2 アルゴリズムの見分け方

分類	方式	重要ポイント
ブロック暗号	**AES ★★★**	**128ビットブロック／鍵128・192・256ビット**
旧ブロック暗号	DES / 3DES	現代の新規採用には不適切・レガシー
ストリーム暗号	ChaCha20（旧RC4は非推奨）	連続データを暗号化、利用環境と認証付き構成が重要
公開鍵	RSA	大きな整数の素因数分解の困難性に基づく
鍵共有	Diffie–Hellman / ECDH	共有秘密を合意する仕組み
楕円曲線暗号	ECC	楕円曲線離散対数問題が基盤（**RSAの素因数分解と異なる**）
ハッシュ	SHA-2（SHA-256等）、SHA-3	固定長要約、衝突耐性など
レガシーハッシュ	MD5 / SHA-1	新規の安全な署名用途に使わない

分類	方式	重要ポイント
耐量子公開鍵暗号	**ML-KEM、ML-DSA、SLH-DSA**	PQCのNIST標準化例。従来のRSA/ECCとの移行課題

ケルクホフスの原理：暗号の安全性はアルゴリズムの秘密ではなく**鍵の秘密**に依存すべき。**暗号を自作しない。**

6.3 PKIの用語

用語	意味	例
CA	証明書の署名・発行などを担う認証局	社内CA・公開CA
RA	登録・身元確認を補助する機関	申請者の本人確認
Root CA	証明書チェーンの信頼の起点	ルート証明書
CRL	失効証明書の一覧を配布	定期的な失効確認
OCSP	証明書単位で失効状態を問い合わせ	`good/revoked/unknown`
HSM	暗号鍵を保護・操作する専用機器	CAの署名鍵保護
TPM	端末の鍵保護・起動測定等を支援するハードウェア信頼基盤	BitLocker・Measured Boot等

OCSPの`good`は「証明書の全条件で安全」を意味しない。期限・署名チェーン・ホスト名・用途なども確認する。

6.4 暗号に対する代表的攻撃

攻撃	狙い	対策・識別
Brute Force	鍵・パスワード総当たり	十分な強度・レート制限・MFA
Dictionary	候補語に基づく推測	弱いパスワードを避ける
Birthday Attack	ハッシュの**衝突**を探す	衝突耐性と長いハッシュ
Replay	正当な通信・認証情報の再利用	nonce・タイムスタンプ・有効期限
MITM	通信の途中へ割り込む	相互認証・適切な証明書検証
Side Channel	時間・電力などの漏れから秘密を推測	実装対策・物理防護
Fault Injection	異常動作を誘発して秘密を得る	耐故障実装・エラー管理
Pass-the-Hash	ハッシュを資格情報として悪用	資格情報保護・管理分離

7. ネットワーク・通信・無線・VPN ★★★（D4）

7.1 OSI 7層は「機器・プロトコル・攻撃」で覚える

層	役割	技術・例	典型攻撃・防御

層	役割	技術・例	典型攻撃・防御
L7 アプリケーション	業務サービス	HTTP、DNS、SMTP	SQLi、XSS、WAF、入力検証
L6 プレゼンテーション	形式・符号化・表現	UTF-8、圧縮、暗号化に関する表現	不適切なエンコード処理、暗号設計
L5 セッション	対話・セッション維持	セッション管理、NetBIOSなど	セッション乗っ取り・適切な失効
L4 トランスポート	ポート・転送制御	TCP、UDP	SYN flood、L4 FW、レート制限
L3 ネットワーク	IP経路選択	IPv4/IPv6、ICMP、OSPF、BGP	IP偽装、経路ハイジャック、ACL
L2 データリンク	フレーム・MAC・隣接	Ethernet、802.1Q、ARP関連	ARP汚染、MAC flooding、DAI
L1 物理	信号・媒体	光、銅線、電波	盗聴・断線、物理保護・冗長化

TCP/IPモデルの大まかな対応：Application（OSI L5〜L7）、Transport（L4）、Internet（L3）、Link（L1〜L2）。**Webセッションをすべて**OSI L5だけの問題と捉えない。

7.2 頻出のポート・番号

技術	デフォルト例	覚え方・補足
FTP	TCP 21（制御）／20（アクティブ時データの典型）	平文、FTPSやSFTPと区別
SSH / SFTP	**TCP 22**	リモート管理・安全な転送
Telnet	TCP 23	平文、避ける
SMTP	TCP 25	メール転送
DNS	**UDP/TCP 53**	名前解決。TCPも使用する
DHCP	UDP 67/68	IP設定の配布
HTTP	TCP 80	Web平文
POP3 / IMAP	TCP 110 / 143	メール取得、暗号化構成別にポートが異なる
NTP	UDP 123	時刻同期
LDAP / LDAPS	TCP/UDP 389 / TCP 636（典型）	ディレクトリ照会とTLS
HTTPS	**TCP 443、HTTP/3はUDP 443**	TLS / QUIC
SMB	TCP 445	ファイル共有、横展開対策

技術	デフォルト例	覚え方・補足
Kerberos	**TCP/UDP 88**	KDCへの認証
RDP	TCP/UDP 3389	リモートデスクトップ
RADIUS	**UDP 1812/1813**	AAA認証/記録
TACACS+	**TCP 49**	機器管理AAA
BGP	TCP 179	AS間経路制御
IKE / NAT-T	**UDP 500 / 4500**	IPsecの鍵交換／NAT通過
L2TP	UDP 1701	**単体では暗号化しない**
SIP	5060、TLS利用時は5061の典型	VoIPのセッション制御

重要：IPsecの**ESP＝IPプロトコル番号50、AH＝51**。これはTCP/UDPのポート番号ではない。

7.3 似ているネットワーク技術の比較

技術	役割	ひっかけポイント
ARP	IPv4宛先の次ホップMACを解決	偽ARP＝MITM。IPv6はNDP
802.1Q VLAN	L2ブロードキャストドメインの論理分割	VLANだけでL3アクセス制御は完成しない
VRF	L3のルーティングテーブルを分離	VLAN（L2）と違う
NAT	IPアドレスの変換	セキュリティ機構そのものではない
PAT/NAPT	IPとポートを変換	1つのIPv4を複数端末で共用
DMZ	外部公開部分と内部ネットワークを分離	WebはDMZ、DBは内部、等
NAC	接続する端末の認証・健全性評価・隔離	方針に合わない端末を検疫
802.1X	ポートベースのアクセス制御	Wi-Fi規格の**802.11**とは別
SDN	ネットワークの制御をプログラマブルにする考え方	制御プレーンと転送プレーンを区別
NFV	FW等のネットワーク機能を仮想化	SDNとは違う軸
Zero Trust	暗黙の信頼をせず継続的に評価	VPN／MFA製品ひとつで完成しない

802.1Xの3者：Supplicant（端末）→ Authenticator（スイッチ/AP）→ Authentication Server（通常RADIUS）。**EAP-TLS**は証明書ベースの認証方式。**LEAP**は歴史的・非推奨。

7.4 IPsecとVPN ★★★

方式	役割	暗号化する？
AH	データ起点認証・完全性・リプレイ保護	**しない**

方式	役割	暗号化する？
ESP	機密性（設定時）、完全性・認証・リプレイ保護	**可能**
IKEv2	鍵交換とSA（Security Association）の交渉	通信保護の鍵を確立
NAT-T	ESPをUDP 4500にカプセル化	NAT通過を支援
Transport Mode	元のIPヘッダーを基本的に残してペイロード等を保護	主にホスト間
Tunnel Mode	元のIPパケット全体を包み外側IPヘッダーを付与	主に拠点間VPN
L2TP/IPsec	L2TPのトンネルをIPsecで保護	L2TP単体は暗号化なし
TLS VPN	TLSを利用するVPN	ブラウザー型やクライアント型
PPTP	レガシーVPN	非推奨

VoIP：SIPは通話の確立、**RTPはメディア転送、SRTPはメディア保護。SIPをTLSにしても、RTPが自動的に暗号化されるわけではない。**

---

8. IAM・認証・アクセス制御 ★★★（D5）

8.1 アクセスの順序

Identification（識別）→ Authentication（認証）→ Authorization（認可）→ Accounting/Accountability（記録・責任追跡）。

段階	例	覚え方
識別	社員IDを入力	**誰だと主張？**
認証	パスキー・カードで検証	**本当に本人？**
認可	顧客DBへの変更を許すか	**何をしていい？**
記録	誰がいつ何をしたかログ保存	**後から追える？**

8.2 アクセス制御モデル

方式	許可を決める基準	例
DAC	**所有者の裁量**	ファイル所有者が共有先を選ぶ
MAC	**強制ラベル・分類**	軍事機密のセキュリティ区分
RBAC	**ロール・職務**	経理ロールに送金申請権限
RuBAC（Rule-Based）	**ルール**	勤務時間外は操作拒否
ABAC	**属性・環境**	社員属性＋端末準拠＋時刻＋文書分類で判断

PAP＝ポリシーを管理、**PIP**＝属性情報を提供、**PDP**＝許可/拒否を**決定**、**PEP**＝判定を**執行**。**PDPとPEPを混同しない。**

8.3 認証の因子と保証レベル

因子	意味	例
Knowledge	**知っている**	パスワード・PIN
Possession	**持っている**	ICカード・FIDOキー
Inherence	**身体的特徴**	指紋・顔

パスワード＋秘密の質問＝知識因子が2つなのでMFAではない。ICカード＋PIN＝所持＋知識でMFA。生体認証やパスキーは実装の認証器特性で保証水準を評価。

保証	何の強さ？	具体例
IAL	**登録時の身元証明**	口座開設時の本人確認
AAL	**ログイン時の認証**	MFA・FIDO2
FAL	**IDプロバイダーからの連携**	IdPのアサーションの保護

生体認証指標：**FAR**＝他人を誤って**通す**、**FRR**＝本人を誤って**拒否**。通常、判定閾値を厳しくするとFAR↓・FRR↑。**CER/EER**＝両者が等しくなる誤り率。

8.4 プロトコル・サービスを一瞬で見分ける

技術	主用途	キーワード・実例
LDAP	IDディレクトリの検索・操作	ADの所属・グループ照会
Kerberos	**チケット認証**	KDC、AS、TGS、TGT、Service Ticket
RADIUS	ネットワークアクセスAAA	VPN、企業Wi-Fi、UDP 1812/1813
TACACS+	機器管理AAA	ルーターへの管理者コマンド、TCP 49
SAML 2.0	企業向けフェデレーション SSO	IdP→SPへの署名付き**XML Assertion**
OAuth 2.0	**認可の委任**	APIに限定的なAccess Token・Scopeを渡す
OpenID Connect（OIDC）	**認証**	OAuth 2.0ベースのID Token、Claims
FIDO2 / WebAuthn	公開鍵・パスキー認証	フィッシング耐性、秘密鍵をサーバーに送らない
SSO	一度の認証で複数サービス利用	IdP障害が広範囲へ影響する場合あり
FIM	組織間の認証連携・信頼関係	社内IdPと外部SaaS

Kerberosの順序：ログインでASから**TGT** → TGTをTGSに提示して**Service Ticket** → サービスに提示。
Kerberosがアクセス先の全リソースの認可を自動保証するわけではない。

SAMLの4要素：Assertion（何を伝える）、Protocol（やり取り）、Binding（どう運ぶ）、Profile（用途でどう組み合わせる）。

OAuthとOIDC：OAuthのAccess Tokenは基本的にAPIアクセスに使う認可資格情報。OIDCのID Tokenは利用者の認証情報をクライアントへ伝える。**Access Tokenをそのままログイン本人証明として扱わない。**

8.5 IAMライフサイクルとJIT

Joiner（入社）→ Mover（異動）→ Leaver（退職）：作成、権限付与、監視、定期レビュー、変更、無効化、廃止までを一貫管理。

- **Privilege Creep**：異動で旧権限が残り増えていく → 権限棚卸し・最小権限・自動プロビジョニング。
- **JIT（Just-in-Time）**：必要な**時間**だけ権限を付与。
- **JEA（Just Enough Administration）**：必要な**範囲**だけ権限を付与。
- **PAM**：特権ID・資格情報・セッションを管理。
- **IGA**：ID・権限の申請、承認、棚卸しと説明責任。
- **垂直権限昇格**：一般→管理者。**水平権限昇格**：他人の同等権限のリソースへ横移動（例：他人の注文IDを見られる）。

---

9. セキュリティテスト・監査・レポート ★★★（D6）

9.1 監査／アセスメント／テストの区別

手法	中核目的	例
監査（Audit）	ルール・基準への準拠を独立性・客観性をもって評価	ISO監査、会計関連統制監査
アセスメント	リスク・統制の状態／有効性を把握	脆弱性評価、管理策の成熟度評価
Examine（検査）	文書・ログ・設定等を調べる	承認チケットを確認
Interview（面談）	人に実態・手順を聞く	運用担当者へヒアリング
Test（テスト）	実際の挙動を検証	退職者IDの停止を試す

統計的サンプリング＝確率に基づく抽出で母集団への推定に利用。**判断的サンプリング**＝高リスク案件などを意図的に選ぶため、統計的に一般化しにくい。

9.2 テストを問題文から選択する

問題文の条件	選ぶもの
設計図が安全な標準に適合するか	**アーキテクチャセキュリティレビュー**
設計段階で攻撃経路・被害・対策を考える	**脅威モデリング**
ソースコードを動かさずに解析	**SAST**
コンパイル後のプログラムを調査	**バイナリ解析**
悪意のある利用の流れを想定	**ミスユースケース**

問題文の条件	選ぶもの
無効な値・異常処理を安全に拒否	**ネガティブテスト**
ifの両分岐を通したか	**分岐カバレッジ**
異なる実行経路を網羅したか	**パスカバレッジ**
Web・AP・DB間で通信できるか	**インターフェーステスト**
実利用者なしでも定期的に購入操作を再現	**シンセティック監視**
実利用者の体感遅延を計測	**RUM**
脆弱性を網羅的に検出	**脆弱性スキャン**
攻撃可能性を承認済み範囲で実証	**ペネトレーションテスト**
攻撃者の戦術・技術を参照	**MITRE ATT&CK**
侵害シナリオを継続的に自動再現	**BAS（Breach and Attack Simulation）**

テストカバレッジ：Statement（文）、Branch/Decision（分岐）、Condition（個々の条件）、Multiple Condition（条件組合せ）、Loop（繰り返し）、Path（実行経路）、Data Flow（変数の定義・使用）。**命令網羅100%でも分岐網羅100%とは限らない。**

ペンテストの前：Chartering（実施許可）→ Discovery → Scanning → Exploitation → Reporting。**ROE（Rules of Engagement）**で対象・時刻・禁止事項・緊急連絡等を決める。**Red Team＝攻撃模擬、Blue Team＝防御、Purple Team＝協働改善。**

9.3 セキュリティプロセスデータ

データ／指標	誰に何を伝えるか
KPI	管理策が計画どおり機能・達成しているか（例：期限内パッチ率）
KRI	リスクが高まっていないか（例：重大脆弱性の未修正件数）
ログ／SIEM	誰が何をしたか、異常の兆候、相関分析
IAM棚卸し	過剰権限、離職者アカウント、異動後の旧権限
バックアップ／リストア記録	取得だけでなく、RTO/RPOに合う復旧ができるか
SETA	Awareness＝気付かせる、Training＝実践させる、Education＝深く理解させる
BC/DR演習記録	連絡・判断・復旧の実効性を証明

マネジメントレビュー：前回の改善、監査結果、指標、利害関係者の意見、リスク評価、目標達成度を経営層が確認し、改善・資源配分を意思決定。**「報告した」だけで完了ではない。**

9.4 発見事項への対応と監査

発見 → 影響・優先度の評価 → 修復／例外承認 → 再テスト → 証拠化 → 経営報告・改善。

- **POA&M**＝Plan of Action and Milestones。弱点、対応策、担当者、期限、進捗の管理記録。

- **例外**＝リスクを消したことではない。根拠、対象、期限、承認者、再評価を文書化。
- **PDCA**＝Plan–Do–Check–Act。**DMAIC**＝Define–Measure–Analyze–Improve–Control。
- **責任ある／協調的開示**＝開発者へ連絡し、修正機会を確保して調整公開。**完全開示**＝詳細を一般公開。**非開示**＝秘密保持。**法令に基づく義務的報告**は任意の開示方針より優先され得る。
- **Google Project Zero**＝期限を設ける脆弱性開示で知られる研究チーム。**米国政府VEP**＝脆弱性を公表するか保有するかを検討する別の政府プロセス。

6種類の外部監査

種類	目的
コンプライアンス	法令・規格・契約への準拠
財務	財務報告・財務諸表の信頼性
業務	業務の効率性・有効性・統制
情報システム	ITのセキュリティと内部統制
統合	複数の監査目的を一体評価
フォレンジック	不正・侵害の証拠調査、事実関係の解明

内部監査の整理：実施許可 → テスト → 報告 → 修復。**監査の計画・実施**：準備（スコープ、成功基準、管理策リスト、ギャップ分析）→監査（証拠、テスト、報告、教訓）。外部委託先（CSP/ISP/MSSP等）も、**実際に持つアクセス権と依存関係**に応じて対象。オンプレ・クラウド・ハイブリッドとも、対面・電子の適切な証拠収集が可能。

---

10. 物理セキュリティ・設備・新しい基盤（D3・D4）

項目	大切なこと	具体例
CPTED	環境設計によって犯罪を起こしにくくする	見通し・動線・照明・自然監視
多層物理防御	敷地→建物→フロア→ラックを段階保護	フェンス・ICカード・警備員・監視カメラ
Tier I	基本的設備	停止が必要になる保守もあり得る
Tier II	設備の容量コンポーネントの冗長化	UPS等を冗長化
Tier III	**同時保守可能**	止めずに計画保守
Tier IV	**単一設備故障への耐性**	フォールトトレラント構成
SCIF	高機密情報を扱うための制限区域	音響・電磁・視覚・物理的漏えい対策
Secure Boot	ブート対象の署名を検証	不正ブートコードを実行させない
Measured Boot	起動状態の測定値を記録	TPMへ測定値を格納
ICS / SCADA / DCS / PLC	産業設備の監視・制御	**人命・安全性・可用性**を重視

項目	大切なこと	具体例
VM	ハイパーバイザー等による仮想マシン	VM Escape、VM Sprawl対策
Container	ホストOSカーネルを共有する隔離実行	イメージ検査、権限抑制
Microservices	アプリを業務機能で分割する設計	API間認証・最小権限
Serverless	実行基盤管理を事業者へ委ねるモデル	コード・IAM・設定責任は残る
Edge/Fog	データ発生場所の近くへ処理を配置	IoT・工場内のゲートウェイ

混同注意：VM＝仮想マシン、コンテナ＝実行環境、マイクロサービス＝アプリ設計、サーバーレス＝基盤管理モデル。**4つは排他的な選択肢ではなく組み合わせ得る。**

10.1 クラウドの責任共有モデル ★★★

モデル	事業者が主に管理	利用者側に残る主要責任
IaaS	物理設備・ハイパーバイザー等の基盤	**ゲストOS、アプリ、データ、IAM、設定**
PaaS	基盤と提供プラットフォーム	**アプリコード、データ、利用権限、設定**
SaaS	インフラ・アプリ運用の多く	**利用者ID・アクセス権、データ管理、設定・契約上の責任**

例： SaaSのストレージ設定を利用者が「全員公開」にすれば、事業者がデータセンターを安全に運用していても漏えいする。**セキュリティ上の役割分担は個々のサービスと契約で確認する。**

---

11. 問題文→即答のトリガー40（横断総復習）

No.	問題文の特徴	答え／判断軸
01	「経営戦略を支援するセキュリティ」	ガバナンス、ビジネスアライメント
02	「危険を調査してから施策を決める」	Due Diligence、リスクアセスメント
03	「妥当な保護を実施する」	Due Care
04	「組織が取ってよいリスクの大枠」	Risk Appetite
05	「対策後に残るリスク」	Residual Risk
06	「年間期待損失」	ALE＝AV×EF×ARO
07	「情報セキュリティのマネジメントシステム認証」	ISO 27001
08	「統制カタログ」	SP 800-53
09	「統制の評価方法」	SP 800-53A
10	「準備→分類→選択→実装→評価→承認→監視」	RMF：SP 800-37
11	「個人データの目的・手段を決める」	Controller
12	「保護要件・アクセス権を決める」	Data Owner

No.	問題文の特徴	答え／判断軸
13	「DBを保管し設定を実装」	Custodian
14	「クラウドに委託した場合の説明責任」	委託元に残る
15	「極秘情報を下位に漏らさない」	Bell-LaPadula
16	「低信頼データで台帳を汚染しない」	Biba
17	「競合A社の情報を見たらB社は見ない」	Brewer–Nash
18	「二人承認・正規取引手順・台帳整合性」	Clark–Wilson
19	「権限が不適切に与えられ得るか」	HRU Safety Problem
20	「最小の役割・権限」	Least Privilege / RBAC
21	「部署＋端末＋時間＋情報分類」	ABAC
22	「認可ポリシーを判定」	PDP
23	「判定を適用して拒否」	PEP
24	「本人でない人を誤って通した」	FAR
25	「本人なのに通れなかった」	FRR
26	「登録時の身元確認」	IAL
27	「認証器の強度」	AAL
28	「認証情報を他社サービスへ安全に連携」	FAL / Federation
29	「XML Assertionで企業SSO」	SAML 2.0
30	「API権限の委任」	OAuth 2.0
31	「Googleでログインの本人確認」	OIDC
32	「TGTとService Ticket」	Kerberos
33	「必要な1時間だけ管理者権限」	JIT / PAM
34	「認証のため端末・スイッチ・RADIUS」	802.1X
35	「暗号化せずパケット認証」	IPsec AH
36	「NAT越えのIPsec」	NAT-T UDP 4500
37	「半年間の統制運用の有効性」	SOC Type 2
38	「疑似利用者で定期監視」	Synthetic Monitoring
39	「復旧できる時点と停止時間」	RPO と RTO
40	「監査で発見した課題の期限付き是正計画」	POA&M

12. 確認テスト：10問（解答は折りたたまず下部）

Q1. 極秘情報を下位区分へ書き出させないモデルは？
Q2. 低信頼な入力を高信頼の台帳に書き込ませないモデルは？
Q3. 取引先SaaSのセキュリティ・可用性を第三者が期間を通じて評価した報告は？
Q4. 財務報告に影響する外部サービスの統制報告はSOC 1か2か？
Q5. データオーナーとカストディアンの責任の境界は？
Q6. OAuth 2.0とOIDCの主用途は？
Q7. 社内Wi-Fiの接続制御で端末・AP・認証サーバーが登場。主となるIEEE規格は？
Q8. BIAで最大許容停止12時間、RTO 8時間、WRT 6時間。問題点は？
Q9. 年間期待損失：AV=500万円、EF=20%、ARO=0.5は？
Q10. 脆弱性を発見したセキュリティ担当がリスクを受容すると宣言してよい？

答え： 1 BLP／2 Biba／3 SOC 2 Type 2（対象範囲次第）／4 SOC 1／5 オーナー＝保護要件・承認、カストディアン＝技術的な管理と運用／6 委任認可と認証／7 802.1X／8 RTO+WRT=14時間＞12時間で許容停止を超える／9 SLE=100万円、ALE=50万円/年／10 いいえ。適切なリスク責任者・権限者による判断と記録が必要。

---

13. 原典・利用上の注意

参照元（ユーザー指定・GitHub `main`）

- Domain 1：セキュリティとリスクマネジメント
- Domain 2：資産のセキュリティ
- Domain 3：セキュリティアーキテクチャとエンジニアリング
- Domain 4：通信とネットワークのセキュリティ
- Domain 5：IAM
- Domain 6：セキュリティの評価とテスト

編集上の注意：元ノートに含まれる歴史的規格、旧版、綴りや表現の揺れをそのまま現行の法的要件・技術推奨として扱わないよう、試験で重要な版・目的の違いに適宜注記した。個別の法的適用判断や最新の標準更新を網羅的に調査した資料ではない。特に試験直前は**用語の識別・責任の所在・順序**を優先し、細かな版番号や日数・ポートは設問条件がある場合に照合すること。

最終メッセージ：「何を守る → 誰が責任を持つ → リスクは何か → どう制御する → 証拠で確認 → 是正し続ける」。これが6ドメインを貫く答え方。